

Procta

SOC 2 / SOC 3 Readiness Assessment & Gap Analysis

Trust Services Criteria · Independent-style review · 20 June 2026

Important. This document is a **readiness / gap assessment** prepared from a review of the organization's source repository, configuration, and internal documentation. It is **not** a SOC 2 examination or attestation and confers no assurance opinion. A SOC 2 Type I or Type II report can only be issued by an independent, licensed CPA firm, and a Type II additionally requires evidence of controls operating over a defined audit period (typically 3–12 months). “Opinions” herein are *readiness conclusions*, not audit opinions. Items with no discoverable evidence are recorded as gaps, not assumed to exist.

1. Executive Summary

Procta is an early-stage, pre-revenue AI exam-proctoring platform built and operated by a single founder with AI-assisted development. The engineering substance is strong for the stage: the application demonstrates mature, automated technical security controls — enforced TLS 1.3, bcrypt password hashing, email-OTP two-factor authentication, PostgreSQL Row-Level Security across 26 tables for tenant isolation, encryption at rest (SSE-S3) with a least-privilege, public-blocked bucket, daily database backups, and a CI pipeline that gates on CodeQL, Semgrep, Trivy, gitleaks secret-scanning, and ~1,488 automated tests. A privacy-by-design architecture (on-device ML; raw video never leaves the student device) and a documented DPIA give it an unusually credible privacy posture for its size.

However, the organization is **not currently ready for a formal SOC 2 audit**. The gaps are almost entirely **governance, people, and process** rather than technology: there is no formal policy suite, a single-person team means **no segregation of duties** and a critical **bus-factor of one**, there is no independent penetration test, no vendor SOC-report / DPA register, no security-awareness training program, and — decisively for a Type II — **no audit period of operating evidence**. The path to audit-ready is well-defined and achievable but depends on standing up governance artifacts and, ideally, a second control owner.

Overall readiness: PARTIALLY READY (technical) · NOT READY (formal audit)

Trust Criterion	Readiness	One-line basis
Security (mandatory)	PARTIAL	Strong technical controls; missing policies, segregation of duties, pentest
Availability	PARTIAL	Daily backups + monitoring; no SLA, DR test, or restore-test evidence
Processing Integrity	PARTIAL	Validation, idempotency, reconciliation, 1,488 tests; no formal control narrative
Confidentiality	PARTIAL	Encryption, RLS, secrets mgmt strong; NDAs / vendor agreements absent
Privacy	PARTIAL	DPIA, DPDP alignment, on-device ML, user rights; formal program partial

2. Scope

This assessment covers the Procta proctoring platform: the FastAPI backend, the PostgreSQL/Redis data tier, the Electron desktop proctoring client, the teacher/admin web dashboard, supporting object storage, and the CI/CD and source-control systems. It evaluates the five AICPA Trust Services Criteria (Security mandatory; Availability, Processing Integrity, Confidentiality, and Privacy included). Physical/data-center controls are inherited from cloud/hosting providers and are assessed only at the carve-out / vendor level.

3. Organization & Environment

Product / DBA	Procta — AI-proctored remote examinations (B2B SaaS)
Legal entity	Not yet incorporated — operated by an individual founder (see LAUNCH_COSTS_AND_SETUP.md). Gap: no legal entity, which itself blocks a clean SOC 2 scope boundary.
Headquarters	India (DPDP Act 2023 regime; INR/GST billing; ap-south-1 data residency)
Industry / type	EdTech · B2B SaaS (coaching institutes, schools, universities)
Team	1 founder + AI-assisted development. Contractors: none identified. Implication: no segregation of duties; bus-factor = 1.
Customer types	Educational institutions and their enrolled students (incl. minors → guardian-consent flow)
Regulatory obligations	India DPDP Act 2023; GDPR-adjacent if EU students; PCI scope minimized via hosted Razorpay checkout (no card data stored)
Hosting / infra	Hostinger KVM (Docker Compose); Caddy reverse proxy; Cloudflare (CDN/edge); PostgreSQL 16 + pgbouncer; Redis; AWS S3 ap-south-1 (Mumbai) for proctoring evidence (India residency ✓). DB-backup residency note: repo backup scripts target Backblaze B2 (no India region) — verify the live cron and migrate to AWS Mumbai to keep backups in-country (see §7).
Source / CI	GitHub + GitHub Actions (CodeQL, Semgrep, Trivy, gitleaks, test gate); Dependabot; pre-commit
Identity	Custom auth (bcrypt + JWT + email-OTP 2FA). No external IdP/SSO (Okta/Workspace/Entra) for the team.

4. Asset & Data Inventory

4.1 Data classification & handling

Data asset	Class	Storage	Encryption	Retention
Webcam / proctoring frames + ID images	Restricted (biometric)	S3 ap-south-1 + local dir	SSE-S3 at rest, TLS 1.3 transit	7d local / 30d (S3)
Pre-violation context frames (ctx_)	Restricted	Client RAM ring → S3 on flag only	SSE-S3 / TLS 1.3	30d (inherits screenshots)
Phone/room-camera frames	Restricted	Redis (transient)	TLS 1.3	24h TTL
Credentials / password hashes	Restricted	PostgreSQL	bcrypt (one-way)	Account lifetime
PII (name, email, roll, DoB, guardian)	Confidential	PostgreSQL (RLS)	TLS 1.3; disk per host	Account lifetime / anonymized on delete
Violations / scores / answers	Confidential	PostgreSQL (RLS)	TLS 1.3	1 year
Secrets / API keys	Restricted	.env (gitignored) + /etc/procta (chmod600)	Filesystem perms	Rotation: ad-hoc (gap)
DB backups (pg_dump)	Restricted	Backblaze B2 (US/EU) — verify vs AWS Mumbai	Provider-side	14-30 days

Observation: a documented data-classification scheme exists implicitly (DPIA retention matrix) but is not formalized as a standalone *Data Classification Policy*. Secret rotation is ad-hoc.

5. Control Testing — Security (Common Criteria)

Control	Evidence reviewed	Result	Recommendation
Authentication — hashing & 2FA	local_auth.py (bcrypt); email-OTP 2FA; JWT sessions	PASS	Enforce 2FA for all admin/teacher accounts; document password policy
Authorization — tenant isolation / least privilege	RLS on 26 tables; db_context; scope spine; superadmin-gated media	PASS	Produce a role-to-permission matrix as audit evidence
Segregation of duties	Single founder; self-merge to main observed	FAIL	Add a second reviewer/approver; require PR review before merge to main
Secrets management	gitleaks (pre-commit + CI); .env gitignored; SECRETS.md; chmod600	PASS	Add scheduled secret rotation + a secrets manager
Encryption in transit	TLS 1.3 (Caddy/Cloudflare); aws:SecureTransport bucket policy	PASS	Maintain; document TLS config as evidence
Encryption at rest	SSE-S3; public-block bucket policy; ap-south-1	PASS	Confirm DB-volume/disk encryption on the KVM host and document it
Vulnerability mgmt — SAST/deps/containers	CodeQL, Semgrep, Trivy, Dependabot in CI	PASS	Add a documented remediation-SLA + periodic review cadence
Penetration testing	None found	GAP	Commission an independent pentest; track findings to closure
Logging & monitoring	Sentry; OBSERVABILITY.md; structured logs	PARTIAL	Centralize logs; add failed-login alerting + defined retention; (no SIEM)
Change management	Git history; CI test gate; branch workflow	PARTIAL	Introduce change tickets + approvals; enable GitHub branch protection + required reviews
Secure development	PR-based flow, automated SAST/secret/dep scans, 1,488 tests	PARTIAL	Document an SDLC policy; enforce mandatory peer review
Security policies (full suite)	Only DPIA, INCIDENT_RESPONSE, PRIVACY, SECRETS, OBSERVABILITY	GAP	Author the ~12 missing policies (see §11)
Security awareness training	None found	GAP	Stand up training + retain completion records

6. Control Testing — Availability, Integrity, Confidentiality, Privacy

6.1 Availability

Control	Evidence	Result	Recommendation
Backups	Daily pg_dump cron (backup_to_b2.sh / restic) → Backblaze B2	PARTIAL	Add restore-test evidence; resolve backup data-residency (see §7)
DR / RTO / RPO	No documented RTO/RPO or DR plan	GAP	Define RTO/RPO; write + test a DR runbook
Uptime / SLA	Load test (3,000 VU) documented; no customer SLA / uptime monitor	PARTIAL	Add uptime monitoring + a published SLA
Capacity / scaling	Hardware governor; load-test report	PARTIAL	Document scaling policy + alerts

6.2 Processing Integrity

Control	Evidence	Result	Recommendation
Input/schema validation	Pydantic strict models; size/path-safety checks	PASS	Maintain
Completeness / retries / idempotency	Bounded upload queues, retry+backoff, offline queue; atomic coupon redemption	PASS	Document the control narrative
Reconciliation / consistency	Session reconciler; status single-source-of-truth sets	PASS	Retain reconciler run logs as evidence
Accuracy (grading)	Pass-mark logic; AI grading advisory w/ human override; tests	PARTIAL	Document accuracy QA + override audit trail

6.3 Confidentiality

Control	Evidence	Result	Recommendation
Sensitive-data handling	On-device ML; media streamed only via auth-gated backend; RLS	PASS	Maintain
Key management / rotation	Bucket/IAM scoped; no formal rotation schedule	PARTIAL	Adopt a secrets manager + rotation schedule
NDA's / confidentiality agreements	None found (solo)	GAP	Execute NDAs with any future staff/contractors
Vendor data-sharing agreements	No DPA/agreement register	GAP	Sign + track DPAs (see §8)

6.4 Privacy

Control	Evidence	Result	Recommendation
DPIA / data minimisation	DPIA.md (DPDP-aligned); on-device ML; minimisation matrix	PASS	Keep current; review annually
Notice & consent	Privacy policy; guardian-consent flow for minors; room-cam consent	PASS	Map each purpose to a legal basis explicitly
User rights (access/delete/correct)	Anonymize-on-delete; student evidence view (no media)	PARTIAL	Document DSAR fulfilment SLA + procedure
Cross-border transfers	ap-south-1 residency; Google/Razorpay/Resend/AWS processors	PARTIAL	Maintain a processor + transfer register

7. Risk Register (key entries)

Risk	Threat / Vulnerability	Impact	Likelihood	Residual
Bus-factor of one	Founder unavailable; no second operator	High	Possible	Risk
No formal policies	Audit/contract blocker; inconsistent control operation	High	Likely	Risk
No independent pentest	Unknown exploitable vulns	High	Possible	Risk
No segregation of duties	Unreviewed change reaches prod	Medium	Likely	Risk
Vendor mgmt gaps	Processor breach w/o DPA recourse	Medium	Possible	Risk
Biometric data breach	Unauthorized access to proctoring imagery	High	Rare	Partial
No DR test	Backups unrestorable when needed	Medium	Rare	Partial
Secret rotation ad-hoc	Stale/leaked credential persists	Medium	Possible	Partial
Windows installer unsigned	SmartScreen / tamper risk at install	Low	Likely	Partial
Backup data residency	DB backups to Backblaze B2 (US/EU) leave India → DPDP gap vs 'in India' stance	High	Likely	Risk

Residual key: **Risk** = material residual risk requiring action; **Partial** = mitigated but not fully closed.

8. Vendor / Sub-processor Management

Vendor	Purpose / data	Criticality	SOC/DPA status
AWS S3 (ap-south-1)	Proctoring image storage (Restricted)	Critical	SOC 2 available (AWS) — not yet collected
Hostinger (KVM)	Application + DB hosting	Critical	Not collected
Cloudflare	CDN / edge / TLS	High	SOC 2 available — not collected
Razorpay	Payments (no card data stored)	High	PCI-DSS; DPA not tracked
Google (Classroom OAuth)	Roster sync; sensitive scope	Medium	OAuth verification pending; CASA n/a
Resend	Transactional email (PII: email)	Medium	DPA not tracked
Backblaze B2	DB backups — NO India region (residency risk, see §7)	High	Not collected; consider AWS Mumbai
Sentry	Error monitoring (may capture metadata)	Medium	SOC 2 available — not collected; scrub PII
GitHub	Source + CI/CD	High	SOC 2 available — not collected

Finding: no central vendor register, no collected SOC reports, and no signed/tracked DPAs. This is a required SOC 2 control area and is currently a gap.

9. Incident Response, HR & Business Continuity

Area	Evidence	Status	Note
Incident response plan	INCIDENT_RESPONSE.md; breach_incidents table; breach runbook	PASS	Strong for stage; add severity SLAs + comms templates
Detection / escalation	Sentry alerts; documented runbook	PARTIAL	Add on-call + failed-login alerting
Postmortems	Process documented; limited historical incidents	PARTIAL	Retain blameless postmortems as they occur
HR — background checks	None (no employees)	N/A	Applies once hiring; document then
HR — confidentiality agreements	None (solo)	GAP	Required before any staff/contractor
HR — onboarding/offboarding access	No documented procedure	GAP	Write joiner/mover/leaver w/ revocation SLA
Business continuity plan	None found	GAP	Author BCP; run a tabletop exercise
Backup restore testing	Backups exist; no restore-test evidence	GAP	Schedule + document quarterly restore tests

10. Type I & Type II Readiness Conclusions

Type I (design & existence, point-in-time) — readiness

Conclusion: NOT YET READY. A meaningful subset of controls exist and are well-designed (authentication, tenant isolation, encryption, vulnerability scanning, incident response, privacy). However, Type I requires the *full* set of Common Criteria controls to exist and be suitably designed, supported by documentation. The absence of a formal policy suite, segregation of duties, a vendor-management program, and an access-control procedure means several criteria have no designed control to test. Estimated effort to Type I-ready: **~6–10 weeks** of governance work (largely documentation + GitHub branch protection + a pentest), assuming a legal entity is formed.

Type II (operating effectiveness over a period) — readiness

Conclusion: NOT READY. Type II additionally requires evidence that controls operated *consistently* over an audit window (commonly 3–6 months). No such period exists yet, change management is informal, and there is no audit-trail of control operation (access reviews, training completions, restore tests, vendor reviews). Earliest realistic Type II window begins only after Type I readiness is achieved and controls have run for the observation period — i.e. **~9–12 months out**.

11. Readiness Scores & Remediation Roadmap

Trust criterion	Score	Status
Security	55 / 100	PARTIAL
Availability	50 / 100	PARTIAL
Processing Integrity	70 / 100	PARTIAL
Confidentiality	60 / 100	PARTIAL
Privacy	70 / 100	PARTIAL
OVERALL (formal SOC 2)	~60 / 100	NOT READY

Remediation roadmap (priority order)

#	Action	TSC	Effort
1	Incorporate a legal entity (defines the audit scope boundary)	All	Low
2	Enable GitHub branch protection + required PR review before merge to main	Security	Low
3	Author the missing policy suite (InfoSec, Access Control, Change Mgmt, Vendor, Data Classification, BCP/DR, Backup, Cryptography, SDLC, Acceptable Use, Retention, Physical/Remote)	Security	Med
4	Stand up vendor register; collect vendor SOC 2 reports; sign + track DPAs	Confidentiality	Med
5	Commission an independent penetration test; remediate + retest	Security	Med
6	Define RTO/RPO; write DR plan; perform + document a backup restore test	Availability	Med
7	Centralize logging; add failed-login alerting + log retention	Security	Med
8	Enforce 2FA for all admin accounts; write password + access-control procedure	Security	Low
9	Adopt a secrets manager with a rotation schedule	Confidentiality	Med
10	Recruit a second control owner / co-founder (addresses bus-factor + SoD)	Security	High
11	Security-awareness training + completion records (once team grows)	Security	Low
12	Begin a 3–6 month Type II observation window once 1–9 are live	All	Time

12. SOC 3-style Public Summary (draft)

The following is a public-facing draft only. A real SOC 3 report may be issued solely by the independent CPA firm that performs the corresponding SOC 2 examination, and only after that examination concludes.

Services. Procta provides an AI-assisted remote exam-proctoring platform for educational institutions, combining a locked-down desktop client with on-device machine-learning detection and a teacher monitoring dashboard.

Scope & criteria. The platform is engineered against the AICPA Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy.

Security & privacy commitments. Data is encrypted in transit (TLS 1.3) and at rest; tenant data is isolated at the database layer; AI inference runs on the student's own device so raw video never leaves it; only minimal, violation-triggered evidence is transmitted and is retained on a defined schedule; access to proctoring media is authenticated and least-privilege.

Current status. Procta operates a strong technical control baseline and is actively building the governance program required for an independent SOC 2 examination. It does not yet hold a SOC 2 or SOC 3 report. This summary reflects a self-assessment of readiness, not an independent opinion.

— End of readiness assessment —